

Developing The Analyst: Creating Career Roadmaps for Intelligently Progressing in CTI



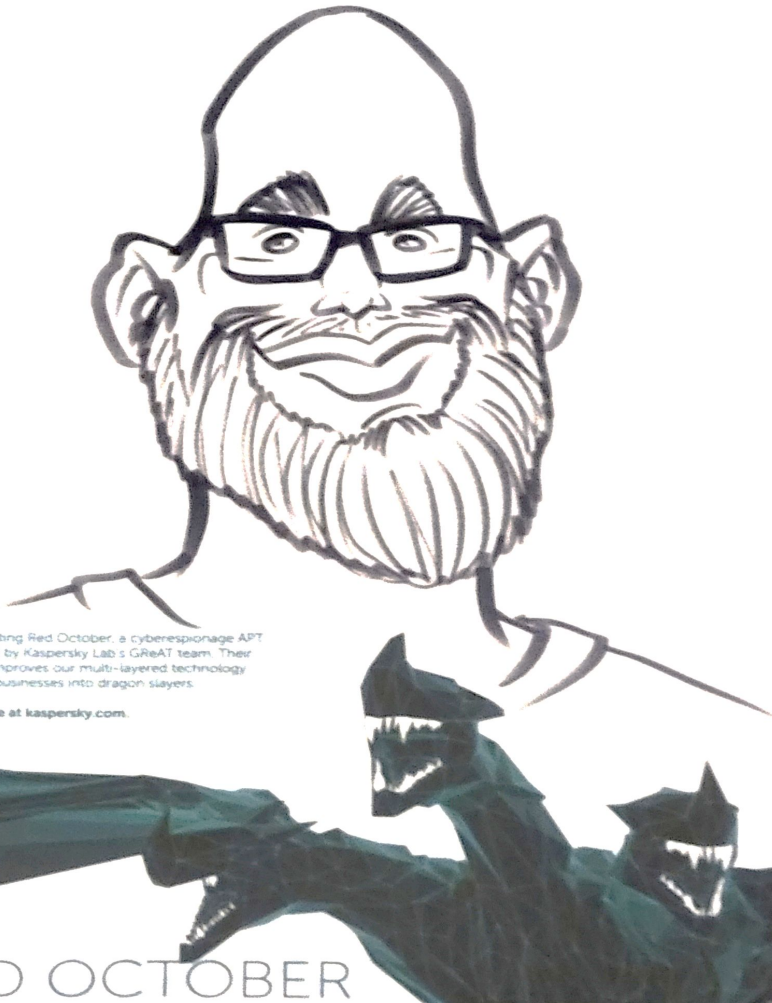
John Doyle

- Mandiant/Google
- SANS CTI Instructor

whoami

KASPERSKY Lab

THE POWER TO FIGHT APTs



```
C:\WINDOWS\system32\cmd.exe
Microsoft Windows [Version 10.0.19043.1889]
(c) Microsoft Corporation. All rights reserved.

C:\Users\John.Doyle> net user John.Doyle
```

- SANS. FOR578 Cyber Threat Intelligence Instructor.
- Mandiant/Google. Principal Intelligence Enablement Consultant.
- Mandiant/Google. Principal Strategic and Incident Response Consultant.
- Mandiant/Google. Principal Advanced Intelligence Integrator.
- Central Intelligence Agency (CIA). Senior Cyber Threat Analyst.
- George Mason University. Adjunct Cyber Security Professor.
- Certifications: CISSP, GCTI, GCFA, GCFE, GNFA, GREM, GPEN, GDAT.

Roll for Initiative



Agenda

- Career Planning as a Process
- Taking a Self-Inventory of Skills
- Defining Goals
- Creating Roadmaps
- The Need to Self-Advocate
- Finding Mentors and Your Chad Along the Way
- Additional Resources



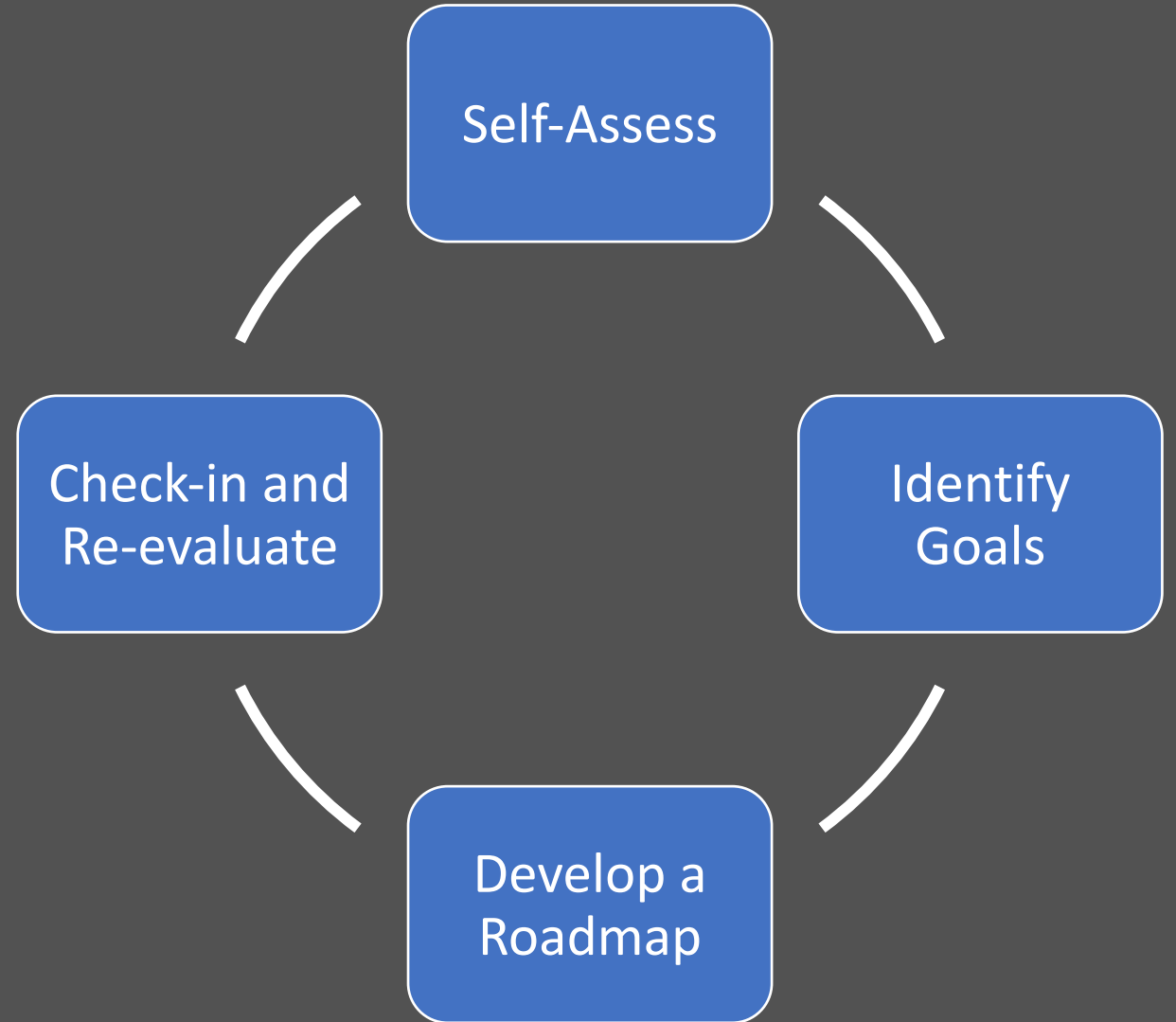
Career Planning is a Process

You control elements of your career...

- Current skills and experiences
- Aspirations
- Positioning

...and hope other elements fall into place...

- Timing
- Availability
- Luck



Know Thyself

- # OneNote or Excel skills inventory

- | Enumerated CTI Analyst Core Competencies Framework with Role Mapping | | | |
|---|--|--|--|
| File Edit View Insert Format Data Tools Extensions Help Last edit was seconds ago | | | |
| | | | |
| 38 100% W 100% 123 456 789 1011121314151617181920212223242526272829303132333435363738394041424344454647484950515253545556575859606162636465666768697071727374757677787980818283848586878889909192939495969798991001011021031041051061071081091101111121131141151161171181191201211221231241251261271281291301311321331341351361371381391401411421431441451461471481491501511521531541551561571581591601611621631641651661671681691701711721731741751761771781791801811821831841851861871881891901911921931941951961971981992002012022032042052062072082092102112122132142152162172182192202212222232242252262272282292302312322332342352362372382392402412422432442452462472482492502512522532542552562572582592602612622632642652662672682692702712722732742752762772782792802812822832842852862872882892902912922932942952962972982993003013023033043053063073083093103113123133143153163173183193203213223233243253263273283293303313323333343353363373383393403413423433443453463473483493503513523533543553563573583593603613623633643653663673683693703713723733743753763773783793803813823833843853863873883893903913923933943953963973983994004014024034044054064074084094104114124134144154164174184194204214224234244254264274284294304314324334344354364374384394404414424434444454464474484494504514524534544554564574584594604614624634644654664674684694704714724734744754764774784794804814824834844854864874884894904914924934944954964974984995005015025035045055065075085095105115125135145155165175185195205215225235245255265275285295305315325335345355365375385395405415425435445455465475485495505515525535545555565575585595605615625635645655665675685695705715725735745755765775785795805815825835845855865875885895905915925935945955965975985996006016026036046056066076086096106116126136146156166176186196206216226236246256266276286296306316326336346356366376386396406416426436446456466476486496506516526536546556566576586596606616626636646656666676686696706716726736746756766776786796806816826836846856866876886896906916926936946956966976986997007017027037047057067077087097107117127137147157167177187197207217227237247257267277287297307317327337347357367377387397407417427437447457467477487497507517527537547557567577587597607617627637647657667677687697707717727737747757767777787797807817827837847857867877887897907917927937947957967977987998008018028038048058068078088098108118128138148158168178188198208218228238248258268278288298308318328338348358368378388398408418428438448458468478488498508518528538548558568578588598608618628638648658668678688698708718728738748758768778788798808818828838848858868878888898908918928938948958968978988999009019029039049059069079089099109119129139149159169179189199209219229239249259269279289299309319329339349359369379389399409419429439449459469479489499509519529539549559569579589599609619629639649659669679689699709719729739749759769779789799809819829839849859869879889899909919929939949959969979989991000100110021003100410051006100710081009101010111012101310141015101610171018101910201021102210231024102510261027102810291030103110321033103410351036103710381039104010411042104310441045104610471048104910501051105210531054105510561057105810591060106110621063106410651066106710681069107010711072107310741075107610771078107910801081108210831084108510861087108810891090109110921093109410951096109710981099110011011102110311041105110611071108110911101111111211131114111511161117111811191120112111221123112411251126112711281129113011311132113311341135113611371138113911401141114211431144114511461147114811491150115111521153115411551156115711581159116011611162116311641165116611671168116911701171117211731174117511761177117811791180118111821183118411851186118711881189119011911192119311941195119611971198119912001201120212031204120512061207120812091210121112121213121412151216121712181219122012211222122312241225122612271228122912301231123212331234123512361237123812391240124112421243124412451246124712481249125012511252125312541255125612 | | | |

Goal Setting Should Facilitate Discussion

Identify experience, skill, ability, role, or responsibility

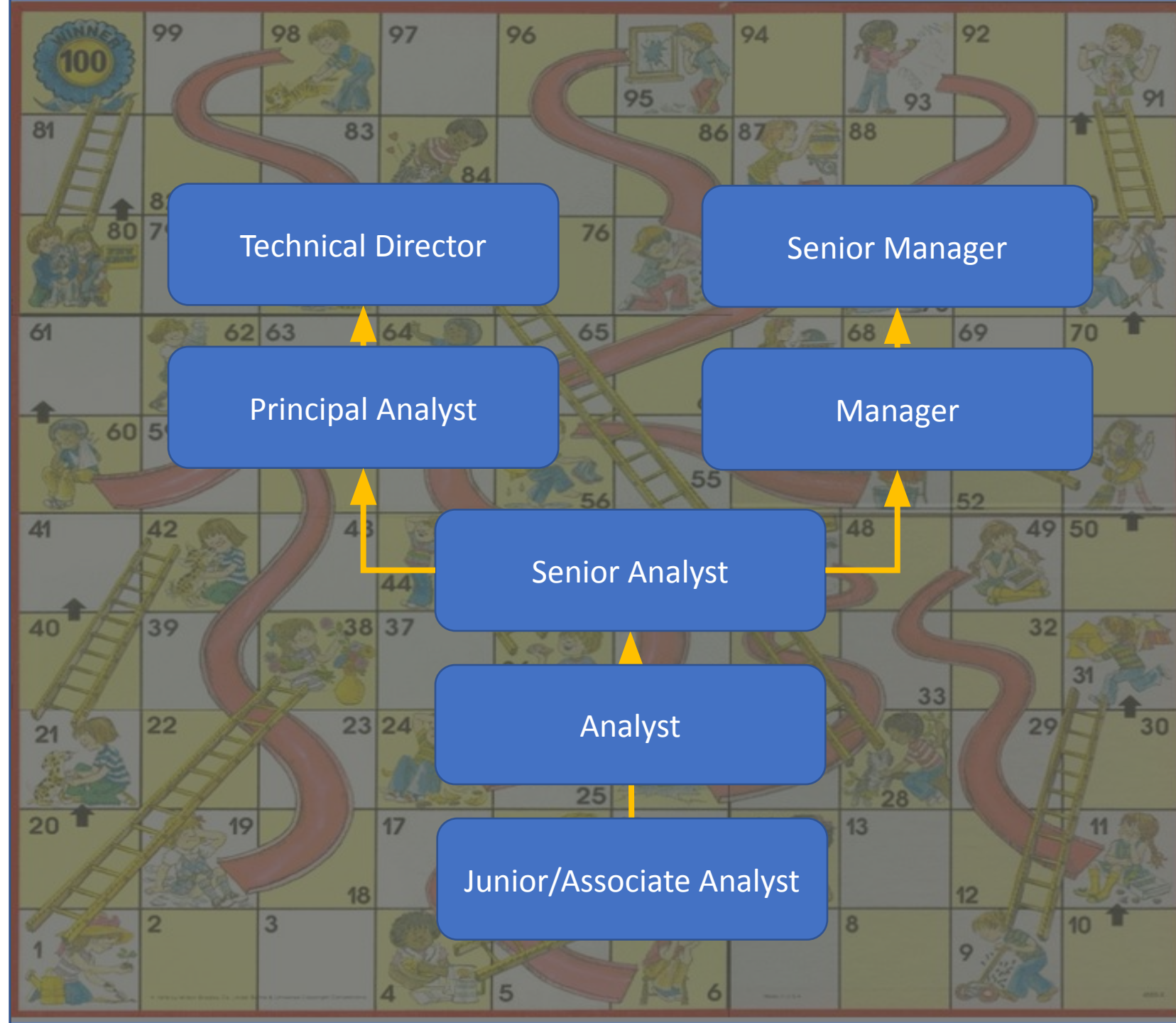
- Compare against self-inventory
- Determine what developing it would look like:
 - Cost
 - Time away from work
 - An ideal time range
 - Prioritize/rank order items
- Define how it will help you in your current role and in the future
- Do internal resources exist to satisfy this/these aspirations?



Goal Setting Should Facilitate Discussion

Career roadmaps:

- Individual contributor path vs. management track
- Trade-offs on upward mobility vs. lateral assignments
- Collaboratively brainstorm future opportunities, identify potential mentors
- Examining what internal resources exist



Goal Setting Should Facilitate Discussion

Now you have a starting point, so we can...

- Identify a path forward and any gaps that require we go outside our organization
- Receive buy in/secure funding
- Adding to quarterly/annual goals for accountability
 - Make milestones feasible! Shift happens
- Identify what you want your bumper sticker/tagline to be for the year



Proposed Training Roadmap for John Doyle

The training roadmap below reflects tangible course offerings and certifications that will help achieve the goals listed below. Items listed in the past have already been taken and are included for comparative and evaluative purposes whereas future items are proposed as tentative based on availability, client demands, and resources as required.

- Goals:**
- Become a recognized SME across AIA and broader Intel functions, advancing not just AIA, but broader Mandiant Threat Intel interests.
 - Improve existing technical skills to provide maximum intel, hunt, and forensic support to CAs/IRs.
 - Stay current on Cyber Threat Intel landscape, frameworks, technological advancements, and vendor improvements.
 - Continue to develop interpersonal situational awareness and conflict navigation skills, polishing soft skills as needed.
 - Apply newly found skills to become marketable for a rotation to IR consulting or Managed Defense.

	2019	2020			2021	
	Q4	Q1	Q2	Q3	Q4	Q1
Technical	Hosted Threat Hunting Brown Bag by Sarah Jones Took HX and PX training in Saba	Participated in SANS Holiday Hack Challenge CTF	Took Binary Triage Course Took Windows Enterprise Incident Response Course Took Linux Enterprise Incident Response Course	Attend Mandiant 101 Take Network Traffic Analysis Course Finish 1 Chapter/week in Practical Malware Analysis book Participate in FE-internal CTF	Take Malware Analysis Crash Course Take Creative Red Team Course	
CTI	Attended FireEye's Cyber Defense Summit Attended Bsides DC Attended Cyberwarcon	Developed Intel Support to IR brown bag content	Attended Virtual Kaspersky SAS conference Joined CIF Instructor cadre	Attend Virtual SANS DFIR Summit Attend Virtual DefCon Safe Mode Get SANS Certification Join Hunt Mission Workshop cadre and develop new content Create Intel Support to IR course		
Other		Ad hoc Nuc modeling training for new malware/code families and spearphishing emails	Took DiSC Workshop Took Leading During Crisis Ad hoc Nuc modeling training on host and network-based IOCs	APT Hunt Package creation	Try to shadow in MD SOC	

Identify Milestones, Track Progress

Create a “brag sheet” to track your progress

- It's easy to get bogged down and forget what we have accomplished during the past year
 - Enter the “brag sheet”
 - Update on regular intervals
 - Revisit goals to see how they line up to all the great work you have accomplished

End of year performance reviews != career conversations

[illegible]

Business Alignment



Audience Type:	Strategic
Customer Roles:	• Chief Information Security • Security Management • Risk Management and Analysts
Customer Tasks:	• Allocate resources • Communicate with executives
Problems They Face:	• No clear investment priorities • Executives are not technical
Value-add from CTI:	• Demystify threats • Prioritize based on business risk

Strategic Analyst || Threat Analyst

- Adapts communication style to resonate with senior personnel
- Takes a systems engineering approach, examining several related threat, trend, and tech issues
- Understands internal culture, business direction, and existing tech stack, risk exposure, and cyber defense efforts
- Identifies signposts of change and can provide indicators and warning
- Can identify the roles and responsibilities within a cyber program
- Able to correlate geopolitical objectives
- Can align motivations with military or intelligence service mission mandate
- ...

Business Alignment

Audience Type:	Operational
Customer Roles:	• Incident Response Team • Vulnerability and Patch Management Team • Forensics Team • Red Team • Purple Team
Customer Tasks:	• Determine attack vectors • Patch systems • Remediate • Hunt for breaches
Problems They Face:	• Event reconstruction tedious • Difficult to identify damage • Difficult to prioritize patches
Value-add from CTI:	• Add context to reconstruction • Prioritize patches • Focus in on potential targets

Technical Analyst | Threat Researcher

- Understand adversary tradecraft and adversary workflows
- Understand common forensic artifacts and evidence of existence and execution
- Provide detailed breakdown of infection chains
- Examine malware or incident response reports to extract IOCs
- Recognize patterns in TTPs employed with a focus on human fingerprints
- Enrich adversary understanding by pivoting in commercial data sets for similar file or network characteristics
- Understand IOC utility and limitations
- Develop high fidelity IOCs
- ...

Business Alignment

Hunting APT28

Executive Summary

This document provides a background on observed attacker activity to familiarize defenders with APT28 and provide some targeted suggestions for hunting for indications of the group's presence in an environment. This document should be used in conjunction with the Windows Hunting documentation, which provides recommendations for hunting techniques and data sources. Activity identified using these documents should not be assumed to be associated with APT28 as many tools and techniques are used by multiple groups. This documentation also does not cover the scope of investigation and is only intended to help with the identification of activity. If malicious activity is identified, consider seeking outside assistance, if needed, especially as this guidance focuses on post-compromise activity indicative of an ongoing and potentially extensive incident. This guide should be used alongside the general Windows hunting guide

Threat Detail

Contents

[APT28 Group Profile](#)

[Attacker Lifecycle](#)

[Attacker Tools and Malware](#)

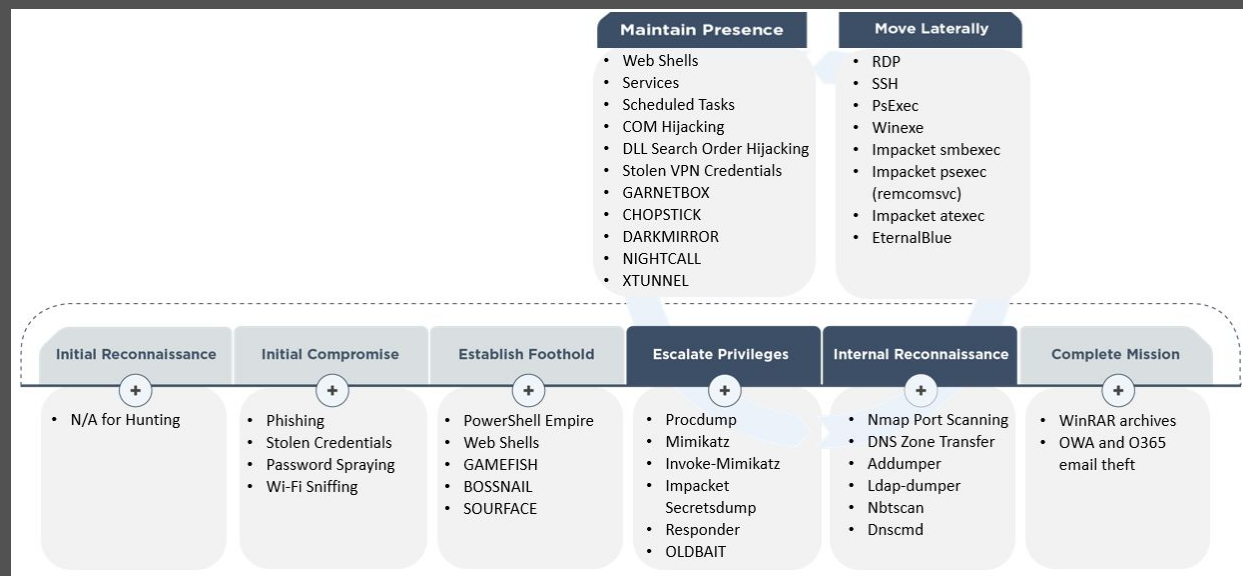
[Attacker Preferences](#)

[Tools and Malware Use](#)

[Sample of Observed Attacker Commands](#)

[Annex 1: YARA and Snort Rules](#)

[Annex 2: Recent Indicators of Compromise](#)



Observed Staging Directories

Directories that the actor has used for storing malware, utilities and/or stolen data.

- %ALLUSERSPROFILE% - C:\ProgramData
- %ALLUSERSPROFILE%\intuit - C:\ProgramData\intuit
- %ALLUSERSPROFILE%\kmsauto - C:\ProgramData\kmsauto
- %ALLUSERSPROFILE%\Ln1 - C:\ProgramData\Ln1
- %ALLUSERSPROFILE%\logs - C:\ProgramData\logs
- %ALLUSERSPROFILE%\Microsoft - C:\ProgramData\Microsoft
- %ALLUSERSPROFILE%\NVIDIA - C:\ProgramData\NVIDIA
- %ALLUSERSPROFILE%\TEMP - C:\ProgramData\TEMP
- %APPDATA% - C:\Users*user*\Appdata\Roaming
- %PROGRAMFILES%\update services - C:\Program Files\update services
- %SYSTEMDRIVE%\temp - C:\temp
- %SYSTEMROOT% - C:\Windows

Business Alignment

Audience Type:	Operational
Customer Roles:	• Incident Response Team • Vulnerability and Patch Management Team • Forensics Team • Red Team • Purple Team
Customer Tasks:	• Determine attack vectors • Patch systems • Remediate • Hunt for breaches
Problems They Face:	• Event reconstruction tedious • Difficult to identify damage • Difficult to prioritize patches
Value-add from CTI:	• Add context to reconstruction • Prioritize patches • Focus in on potential targets

Vulnerability Intelligence Analyst

- Understand the patching lifecycle, organizational considerations, prioritization criteria, and SLAs
- Employ CVSS, CVE, and how vendor risk scoring scales to establish a patch prioritization criteria
- Maintain situational awareness on adversaries using weaponized vulnerabilities or if they are POC
- Familiarity with modern operating system memory protections, application, and network security controls
- Knowledge of the organization's tech stack, asset inventory system, CMDB, and gold image process
- Explain exploit chains using n-days and 0-days, how exploit code works, and how patches break parts of the chain
- ...

Business Alignment



Technical Analyst | Threat Researcher

- Examine malware or incident data (reports, tickets, etc.) to extract relevant IOCs
- Understand the enterprise security stack and relevant internal partners
- Communicate findings using standardized nomenclature (STIX/TAXII, JSON, etc.) security controls can ingest
- Craft detections using YARA, Snort, Suricata, etc.
- Curate and evaluate threat feeds
- ...

Audience Type:	Tactical
Customer Roles:	• Security Operations Center • Network Operations Center
Customer Tasks:	• Push indicators to security tools
Problems They Face:	• False positives • Alert overload
Value-add from CTI:	• Validate and prioritize indicators • Prioritize alerts

Self Advocate Interests, Self-Promote Work

Make your ambitions know to leadership and peers

- Don't expect others to know your aspirations without being explicit
- Helps others know to flag opportunities they come across
- Finds potential mentors
- Establishes personal brand

Perhaps scope creep, but...

- Positioning yourself is important
- Letting contributions speak for themselves is a risky endeavor
- This also reduces the chance of being disappointed come promotion/comp package re-evaluation time

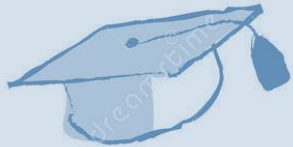
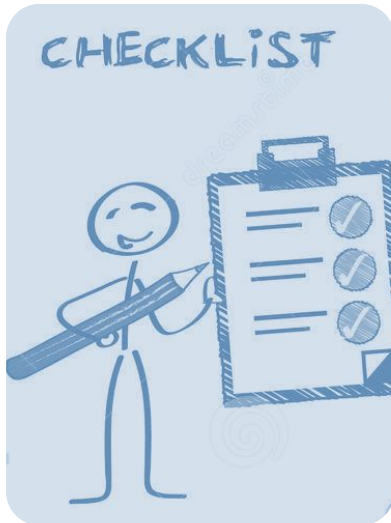
Self-Promotion Wheel



We All Need Champions in Our Corner



Only You Control Your Future



QUALIFICATION

Self-Inventory

Identify Goals

- Skills and Experiences
- Business Justification
 - How will this make you a more valuable employee?
- Internal Opportunities?
 - Rotational assignments, training, etc.?
- External Opportunities and Cost

Self-Advocate, Responsibly Self-Promote

- “Find your Chad”
- Build Support Network and Mentor Base

Create Rough Timelines

Schedule Career Conversation(s)

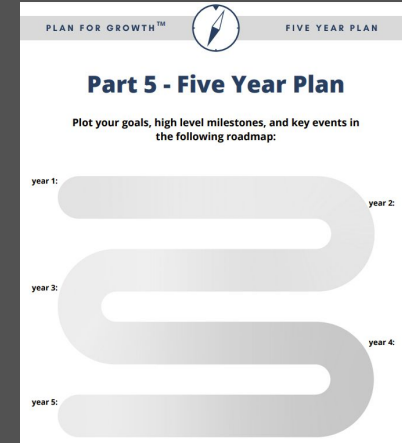
- Get Leadership Buy-in, Start Planning

Additional Resources

Related blog posts, templates, and books recommendations for consideration.

- [Introducing the Mandiant Cyber Threat Intelligence \(CTI\) Analyst Core Competencies Framework Blog](#)
- [Mandiant CTI Analyst Core Competencies Framework \(direct link\)](#)
- [CSV CTI Framework Enumeration and Mapping to Some CTI Roles](#)
- [Mapping FOR578 Coverage to the CTI Core Competencies Framework](#)
- [Breaking Into the CTI Field: Demystifying the Interview Process and Practice Interview Questions](#)
- [How Red Canary Recruits CTI Talent](#)
- [What to Expect When Interviewing at Dragos](#)
- ["Intelligently Developing a Cyber Threat Analyst Workforce" SANS Podcast](#)
- [Katie Nickels' Blog on Getting Started in CTI](#)
- [Katie Nickels' CTI Self Study Plan \(pt. 1\)](#)
- [Katie Nickels' CTI Self Study Plan \(pt. 2\)](#)

- [Sierra's Intelligence Analysis Field Guide](#)



- [Brag Sheet Template](#)

Books:

- [The Manager's Path by Camille Fournier](#)
- [The Power of Presence: Unlock Your Potential to Influence and Engage Others](#)
- [Made to Stick: Why Some Ideas Survive and Others Die](#)

Thank you for your time!



@_John_Doyle